PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Sécurisation d'un serveur Windows

03-170 ANSSI - Mise en œuvre sécurisée d'un serveur Windows — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. Le mode Server Core doit être privilégié pour offrir une surface d'attaque plus réduite que le mode Desktop Experience.
2. L'utilisation de l'utilitaire djoin est recommandée pour joindre un serveur au domaine Active Directory AD-DS.
3. Le chiffrement des disques système et de données avec BitLocker permet de se prémunir des risques de vol.

Prérequis de sécurité matérielle et accès

Notion	À retenir
Protections matérielles	Activer un **TPM version 2** (matériel ou virtuel) et le mode **UEFI Secure Boot**. Privilégier la configuration **Secured-core** (si matériel compatible) dès **Windows Server 2022**.
Contrôle des accès	Vérifier l'**accès physique** et les **accès console** via **IPMI** (serveur physique) ou via la **console de l'hyperviseur** (serveur virtuel).

Installation du serveur Windows

Notion	À retenir
Choix du mode	Privilégier **Server Core** (surface d'attaque réduite). Utiliser **Desktop Experience** si rôles/fonctionnalités indisponibles.
Sécurité native	Conserver **UAC** et **pare-feu Windows Defender**. Garder **IPv6** actif. Si **RDP** : ne pas désactiver **NLA**.
Mise à jour/Domaine	Mettre à jour (sources **Microsoft Update**) **avant connexion au réseau de production**. Compte ordinateur créé dans l'**OU** cible, jonction par `djoin` ; heure des **contrôleurs de domaine** (**Kerberos**) ; **LAPS** pour les administrateurs locaux.
Séparation rôles	Ne pas colocaliser rôles altérant la sécurité (ex: **IIS** et **AD-CS**) car besoins de sécurité différents.

Recommandations de configuration post-installation

Notion	À retenir
Stockage et chiffrement	Stocker les données (ex: **AD-CS**, **WID**, **SQL**) **hors du disque système**. Chiffrer disques système et données avec `BitLocker`.
Sécurité virtualisée	Activer la **VBS** et les composants dépendants comme **Credential Guard** (attention aux incompatibilités avec certains rôles/applications).
Certificats et privilèges	Remplacer les certificats autosignés (**RDP**, **IIS**) par une **infrastructure de gestion de clés**. Appliquer le **moindre privilège** (comptes de service, applications, administration).
Durcissement et communications	Durcir via le kit **SCT** ou le module PowerShell `OSConfig` (**Windows Server 2025**). Configurer **IPSec** pour les serveurs critiques.

État final de l'installation

> Une fois les bonnes pratiques mises en œuvre, le serveur membre est prêt à recevoir les rôles, services et applications demandés, tout en exposant une **surface d'attaque réduite**. D'autres étapes de sécurisation seront nécessaires en fonction des **fonctionnalités installées ultérieurement**.

Pièges et confusions

- ⚠ Désactiver IPv6 alors qu'il est utilisé pour les communications internes vers le serveur.
- ⚠ Désactiver la NLA lors de l'utilisation du RDP.
- ⚠ Colocaliser en production des rôles ayant des besoins de sécurité contradictoires comme une autorité de certification et un serveur web.
- ⚠ Oublier d'activer le TPM en version 2 avant l'installation.

Sigles et définitions

TPM	composant matériel ou virtuel de sécurité
Secured-core	configuration renforcée des serveurs physiques ou virtuels
Server core	mode d'installation contenant moins de composants
LAPS	outil pour définir des mots de passe forts et différents pour les comptes administrateurs locaux
NLA	authentification au niveau réseau
OU	conteneur Active Directory dans lequel un compte ordinateur doit être créé
Djoin	utilitaire recommandé pour joindre un serveur au domaine
VBS	sécurité basée sur la virtualisation

Auto-test

1. Quelle version du TPM doit être activée avant l'installation ?
2. Quel mode d'installation offre une surface d'attaque plus réduite ?
3. Quel utilitaire utiliser pour joindre un serveur au domaine ?
4. Que ne faut-il jamais désactiver sur un serveur Windows ?
5. Quel outil permet de durcir l'environnement d'un serveur Windows ?

Réponses : **1.** version 2 · **2.** Server Core · **3.** Djoin · **4.** IPv6 · **5.** SCT

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.